

Analyse du Scan Trivy - Instana Agent 1.315.1

Résumé Exécutif

Image analysée: `instana-agent-1.315.1.tar`
Base OS: Red Hat Enterprise Linux 8.10
Date du scan: 2026-04-15
Outil: Trivy 0.69.3

Statistiques des Vulnérabilités

Sévérité	Nombre	Pourcentage
CRITICAL	0	0%
HIGH	9	3.2%
MEDIUM	115	40.4%
LOW	161	56.5%
TOTAL	285	100%

Comparaison avec la Version 1.316.1

Métrique	v1.315.1	v1.316.1	Évolution
CRITICAL	0	0	➡ Stable
HIGH	9	9	➡ Stable
MEDIUM	115	110	✅ -5 (-4.3%)
LOW	161	157	✅ -4 (-2.5%)
TOTAL	285	276	✅ -9 (-3.2%)

Conclusion: La version 1.316.1 montre une **légère amélioration** avec 9 vulnérabilités en moins, principalement dans les catégories MEDIUM et LOW.

Analyse Détaillée

✅ Points Positifs

- Aucune vulnérabilité **CRITICAL** détectée
- Dépendances **Java saines** - Tous les fichiers JAR (sensors Instana) montrent 0 vulnérabilité
- Image de base **officielle** - Red Hat UBI 8.10 avec support officiel
- Même profil de **sécurité** que la v1.316.1 pour les vulnérabilités HIGH

⚠️ Vulnérabilités HIGH (9 CVEs)

Les 9 vulnérabilités HIGH sont **identiques** à celles de la version 1.316.1 :

1. libnghttp2 - CVE-2026-27135

- **Package:** libnghttp2 1.33.0-6.el8_10.1
- **Impact:** Dénî de service via frames HTTP/2 malformées
- **Statut:** **Correctif disponible** → 1.33.0-6.el8_10.2
- **Action:** ✅ **MISE À JOUR RECOMMANDÉE**

2. libcap - CVE-2026-4878

- **Package:** libcap 2.48-6.el8_9
- **Impact:** Escalade de privilèges via race condition TOCTOU
- **Statut:** affected
- **Action:** ⚠️ Surveiller les mises à jour Red Hat

3-4. libarchive - CVE-2026-4424, CVE-2026-33948

- **Package:** libarchive 3.3.3-6.el8_10
- **Impact:** Divulcation d'informations, lecture hors limites
- **Statut:** affected
- **Action:** ⚠️ Surveiller les mises à jour

5-9. Autres bibliothèques système

- Vulnérabilités dans curl, glibc, jq avec statut "affected"
- Pas de correctifs immédiats disponibles

📦 Packages Critiques à Surveiller

Bibliothèques Réseau et Sécurité

curl/libcurl (7.61.1-34.el8_10.10) - 6 CVEs MEDIUM

- ⚠️ **Version plus ancienne** que la 1.316.1 (7.61.1-34.el8_10.11)
- CVE-2025-13034: Contournement du pinning de clé publique
- CVE-2025-14017: Bypass de sécurité TLS multi-thread
- CVE-2026-1965: Bypass d'authentification Negotiate
- CVE-2026-3783: Fuite de token OAuth2
- CVE-2026-3784: Réutilisation incorrecte de connexion proxy
- CVE-2026-3805: Use-after-free

glib2 (2.56.4-168.el8_10) - 11 CVEs MEDIUM/HIGH

- CVE-2025-14087: Buffer underflow dans GVariant parser

- CVE-2025-14512: Integer overflow dans GIO
- CVE-2026-1484: Integer overflow dans g_base64_encode()
- CVE-2026-1489: Corruption mémoire via overflow Unicode
- CVE-2023-29499: Offset table non vérifié
- CVE-2023-32611: Lenteur avec entrées non-normales
- CVE-2023-32665: Désérialisation non conforme
- CVE-2025-3360: Integer overflow ISO 8601
- CVE-2025-7039: Buffer under-read
- CVE-2026-0988: DoS via integer overflow
- CVE-2026-1485: DoS local via buffer underflow

glibc (2.28-251.el8_10.31) - 3 CVEs MEDIUM

- CVE-2026-4046: DoS via fonction iconv()
- CVE-2026-4437: Parsing DNS incorrect
- CVE-2026-4438: Hostname DNS invalide

coreutils-single (8.30-16.el8_10) - 1 CVE MEDIUM

-  **Version plus ancienne** que la 1.316.1 (8.30-17.el8_10)
- CVE-2025-5278: Heap buffer under-read dans sort

Différences Clés entre v1.315.1 et v1.316.1

Packages Mis à Jour dans v1.316.1

1. **curl** : 7.61.1-34.el8_10.10 → 7.61.1-34.el8_10.11
 - Amélioration de sécurité mineure
2. **coreutils-single** : 8.30-16.el8_10 → 8.30-17.el8_10
 - Correctifs de bugs et sécurité
3. **Réduction de 9 vulnérabilités** (5 MEDIUM + 4 LOW)
 - Amélioration globale du profil de sécurité

Vulnérabilités Identiques

- Les 9 vulnérabilités HIGH sont présentes dans les deux versions
- Même image de base RHEL 8.10
- Mêmes bibliothèques système principales (glibc, glib2, libssh, etc.)

Plan d'Action Recommandé

Actions Immédiates (Priorité 1)

1. Migrer vers la version 1.316.1

```
# Télécharger la nouvelle version
skopeo copy docker://containers.insta.io/instana/release/agent/static:1.316.1 \
  docker-archive:instana-agent-1.316.1.tar

# Scanner la nouvelle version
trivy image instana-agent-1.316.1.tar
```

Bénéfices: 9 vulnérabilités en moins, packages système plus récents

2. Mettre à jour libnghttp2 (après migration)

```
microdnf update libnghttp2
```

Ceci corrige la seule vulnérabilité HIGH avec correctif disponible.

Actions à Court Terme (Priorité 2)

3. Surveiller les advisories Red Hat

- S'abonner aux notifications RHSA (Red Hat Security Advisory)
- URL: <https://access.redhat.com/security/security-updates/>

4. Planifier une mise à jour vers RHEL 9

- RHEL 8.10 est en fin de cycle de vie standard
- RHEL 9 offre des versions plus récentes des bibliothèques système
- Considérer la migration vers `ubi9-minimal` comme image de base

Actions Continues (Priorité 3)

5. Automatiser les scans de sécurité

```
# Script de comparaison de versions
#!/bin/bash
for version in 1.315.1 1.316.1; do
  trivy image --format json --output instana-agent-$version.json \
    instana-agent-$version.tar
done
```

6. Implémenter une politique de mise à jour

- Scans hebdomadaires automatisés
- Mise à jour mensuelle des images de base
- Tests de régression après chaque mise à jour

Configuration Kubernetes Recommandée

```
apiVersion: v1
kind: Pod
metadata:
  name: instana-agent
spec:
  securityContext:
    runAsNonRoot: true
    runAsUser: 1000
    fsGroup: 1000
    seccompProfile:
      type: RuntimeDefault
  containers:
    - name: instana-agent
      image: containers.instana.io/instana/release/agent/static:1.316.1 # version recommandée
      securityContext:
        allowPrivilegeEscalation: false
        readOnlyRootFilesystem: true
        capabilities:
          drop:
            - ALL
          add:
            - NET_BIND_SERVICE
            - SYS_PTRACE # Requis pour l'agent Instana
      resources:
        limits:
          memory: "2Gi"
          cpu: "1000m"
        requests:
          memory: "512Mi"
          cpu: "200m"
```

Network Policies

```
apiVersion: networking.k8s.io/v1
kind: NetworkPolicy
metadata:
  name: instana-agent-netpol
spec:
  podSelector:
    matchLabels:
      app: instana-agent
  policyTypes:
    - Egress
  egress:
    - to:
        - namespaceSelector: {}
      ports:
```

```
- protocol: TCP
  port: 443 # Backend Instana
- to:
  - podSelector: {}
ports:
- protocol: TCP
  port: 42699 # Agent communication
```



Évaluation du Risque

Niveau de Risque Global: MOYEN ●

Justification:

- ✓ Aucune vulnérabilité CRITICAL
- ✓ Composants Java (sensors) sans vulnérabilités
- ⚠ 9 vulnérabilités HIGH dans les bibliothèques système
- ⚠ 115 vulnérabilités MEDIUM nécessitant surveillance
- ⚠ Packages système légèrement plus anciens que v1.316.1
- ✓ 1 correctif HIGH disponible (libnghttp2)

Facteurs Atténuants

- Isolation conteneur** - L'agent s'exécute dans un conteneur isolé
- Principe du moindre privilège** - Peut être configuré avec des capacités limitées
- Image de base officielle** - Support et mises à jour Red Hat
- Composants métier sains** - Les sensors Instana n'ont pas de vulnérabilités
- Version plus récente disponible** - La v1.316.1 corrige 9 vulnérabilités

Facteurs Aggravants

- RHEL 8.10** - Approche de la fin de support standard
- Bibliothèques système anciennes** - Versions datées de curl, glibc, etc.
- Pas de correctifs immédiats** - Pour 8 des 9 vulnérabilités HIGH
- Version obsolète** - La v1.316.1 est disponible avec moins de vulnérabilités



Analyse Comparative Détaillée

Évolution des Vulnérabilités

Version 1.315.1 → 1.316.1

CRITICAL:	0	→	0	(=)
HIGH:	9	→	9	(=)
MEDIUM:	115	→	110	(-5, -4.3%)
LOW:	161	→	157	(-4, -2.5%)

TOTAL : 285 → 276 (-9, -3.2%)

Packages Améliorés

Package	v1.315.1	v1.316.1	Impact
curl	7.61.1-34.el8_10.10	7.61.1-34.el8_10.11	Correctifs de sécurité
coreutils-single	8.30-16.el8_10	8.30-17.el8_10	Correctifs de bugs

Recommandation de Migration

FORTEMENT RECOMMANDÉ de migrer vers la version 1.316.1 pour :

- ✓ Réduction de 9 vulnérabilités
- ✓ Packages système plus récents
- ✓ Correctifs de sécurité additionnels
- ✓ Même niveau de compatibilité



Recommandations Finales

Pour l'Environnement de Production

- ⚠ **Migrer vers la version 1.316.1** - Amélioration de sécurité mesurable
- ✓ **Appliquer les mesures de mitigation** - SecurityContext, NetworkPolicies
- 📅 **Planifier la mise à jour libnghttp2** - Dès que possible
- 📅 **Planifier la migration RHEL 9** - Dans les 6-12 prochains mois

Pour l'Équipe de Sécurité

- 🔍 **Scans automatisés** - Intégrer Trivy dans la CI/CD
- 📊 **Tableau de bord** - Suivre l'évolution des vulnérabilités entre versions
- 🚨 **Alertes** - Notifications pour les nouvelles CVEs CRITICAL/HIGH
- 📄 **Documentation** - Maintenir un registre des décisions de sécurité

Pour l'Équipe DevOps

- 🐳 **Image de base** - Évaluer ubi9-minimal pour les futures versions
- 🔧 **Automatisation** - Scripts de mise à jour et de test
- 📦 **Registre privé** - Considérer un registre interne avec scanning
- 🔒 **Signature d'images** - Implémenter Cosign/Notary pour la vérification
- 🔄 **Politique de mise à jour** - Toujours utiliser la dernière version mineure



Ressources Utiles

- [Red Hat Security Advisories](#)

- [Trivy Documentation](#)
- [Instana Agent Documentation](#)
- [NIST National Vulnerability Database](#)
- [CVE Details](#)
- [Instana Release Notes](#)



Checklist de Migration v1.315.1 → v1.316.1

- ☐ Télécharger et scanner la version 1.316.1
 - ☐ Comparer les résultats de scan (fait )
 - ☐ Tester la version 1.316.1 en environnement de développement
 - ☐ Valider la compatibilité avec les applications monitorées
 - ☐ Planifier la fenêtre de maintenance
 - ☐ Mettre à jour les manifestes Kubernetes/Docker
 - ☐ Déployer en environnement de staging
 - ☐ Valider les métriques et traces
 - ☐ Déployer en production
 - ☐ Surveiller les logs et performances
 - ☐ Documenter la migration
-

Date du rapport: 2026-04-15

Analyste: Bob (AI Security Analyst)

Version du document: 1.0

Versions comparées: 1.315.1 vs 1.316.1